VulnGuard API — Endpoint Summary

COM661 Full Stack Strategies and Development

CW1 — Individual Full Stack Application Development (Back End)

Student: Hritik Kumar Sah

Student Number: B00923557

Overview

The VulnGuard API is a RESTful back-end service built with **Flask** and **MongoDB** for managing cybersecurity vulnerabilities. All endpoints are versioned under `/api/v1/`.

Base URL: `http://localhost:5000/api/v1`

Authentication: JWT via `x-access-token` HTTP header. Tokens are obtained from the `/auth/login` endpoint. Token expiry is configurable (default: 1 hour). A blacklist collection supports secure logout.

Roles (RBAC):

Role	Permissions
admin	Full access — manage users, create/update/delete vulnerabilities, all analytics
analyst	Create/update vulnerabilities, add remediation steps and activity logs, view analytics
guest	Read-only access to public endpoints

Standard Response Format:

```
{
  "status": "success" | "error",
  "data": { ... },
  "message": "Human-readable message",
  "pagination": { "page": 1, "per_page": 10, "total": 100, "pages": 10 }
}
```

---

1. Health Check

#	Method	Endpoint	Description	Auth	Roles
1	`GET`	`/api/v1/health`	API health status check	No	—

Response:

```
{ "status": "success", "message": "VulnGuard API is running" }
```

---

2. Authentication Endpoints

Blueprint prefix: `/api/v1/auth`

#	Method	Endpoint	Description	Auth	Roles
2	`POST`	`/api/v1/auth/register`	Register a new user account	No	—
3	`POST`	`/api/v1/auth/login`	Authenticate and receive JWT token	No	—

#	Method	Endpoint	Description	Auth	Roles
4	GET	/api/v1/auth/profile	Get current user's profile	Yes	Any
5	PUT	/api/v1/auth/profile	Update current user's profile	Yes	Any
6	POST	/api/v1/auth/refresh	Refresh JWT token before expiry	Yes	Any
7	PUT	/api/v1/auth/change-password	Change current user's password	Yes	Any
8	POST	/api/v1/auth/logout	Logout (blacklist current token)	Yes	Any

Request / Response Details

POST /auth/register

```
// Request Body
{
  "username": "john_doe",
  "email": "john@example.com",
  "password": "SecureP@ss1"
}
// Response 201
{
  "status": "success",
  "data": { "_id": "...", "username": "john_doe", "email": "john@example.com",
"role": "analyst" },
  "message": "User registered successfully"
}
```

POST /auth/login

```
// Request Body
{ "email": "john@example.com", "password": "SecureP@ss1" }
// Response 200
{
  "status": "success",
  "data": {
    "token": "<JWT>",
    "user": { "_id": "...", "username": "john_doe", "email":
"john@example.com", "role": "analyst" }
  },
  "message": "Login successful"
}
```

PUT /auth/profile — Update username and/or email.

PUT /auth/change-password

```
{ "current_password": "OldP@ss1", "new_password": "NewP@ss2" }
```

3. Vulnerability Endpoints

Blueprint prefix: `/api/v1/vulnerabilities`

#	Method	Endpoint	Description	Auth	Roles
9	GET	/api/v1/vulnerabilities/	List vulnerabilities (paginated, filtered)	No	—
10	GET	/api/v1/vulnerabilities/<vuln_id>	Get single vulnerability by ID	No	—
11	POST	/api/v1/vulnerabilities/	Create a new vulnerability	Yes	admin, analyst
12	POST	/api/v1/vulnerabilities/bulk	Bulk create 2–50 vulnerabilities	Yes	admin, analyst
13	PUT	/api/v1/vulnerabilities/<vuln_id>	Update an existing vulnerability	Yes	admin, analyst
14	DELETE	/api/v1/vulnerabilities/<vuln_id>	Delete a vulnerability	Yes	admin
15	GET	/api/v1/vulnerabilities/nearby	Geospatial: find nearby vulnerabilities	No	—

Query Parameters for GET /vulnerabilities/

Parameter	Type	Description
page	int	Page number (default: 1)
per_page	int	Items per page (default: 10, max: 100)
severity	string	Exact match: Critical, High, Medium, Low, Informational
status	string	Exact match: Open, In Progress, Patched, Accepted Risk
asset_type	string	Filter by asset type
department	string	Filter by department
assigned_to	string	Filter by assignee
patch_applied	boolean	Filter by patch status
severity_in	string	Comma-separated severity values ($in)
status_in	string	Comma-separated status values ($in)
title_regex	string	Regex search on vulnerability_title
min_cvss / max_cvss	float	CVSS score range filter
search	string	Full-text search ($text)

Parameter	Type	Description
`or_severity`, `or_status`, `or_min_cvss`, `or_department`	string	$or combinators
`after`	ObjectId	Cursor-based pagination (keyset)
`sort_by`	string	Sort field (default: created_at)
`sort_order`	string	asc or desc (default: desc)

POST /vulnerabilities/ — Request Body

```
{
  "vulnerability_title": "SQL Injection in Login Form",
  "description": "The login form is vulnerable to SQL injection attacks...",
  "cve_id": "CVE-2025-12345",
  "severity": "Critical",
  "status": "Open",
  "cvss_score": 9.8,
  "asset_name": "web-app-01.example.com",
  "asset_type": "Application",
  "vulnerability_type": "Software",
  "discovery_method": "Scan",
  "department": "Engineering",
  "reported_by": "j.smith",
  "affected_versions": ["1.0", "1.1"],
  "attack_vector": "Network",
  "exploitability": "Functional",
  "patch_due_date": "2026-04-15T00:00:00Z",
  "patch_applied": false,
  "assigned_to": "a.jones",
  "location": { "lng": -5.9301, "lat": 54.5973 }
}
```

GET /vulnerabilities/nearby — Query Parameters

Parameter	Type	Description
`lng`	float	**Required.** Longitude of reference point
`lat`	float	**Required.** Latitude of reference point
`radius`	float	Search radius in km (default: 50)
`limit`	int	Maximum results (default: 10, max: 100)

Uses MongoDB `$geoNear` aggregation with a `2dsphere` index.

---

4. Remediation Step Endpoints (Sub-document CRUD)

Blueprint prefix: `/api/v1/vulnerabilities`

#	Method	Endpoint	Description	Auth	Roles
16	GET	/api/v1/vulnerabilities/<vuln_id>/remediation-steps	List all remediation steps	Yes	Any
17	GET	/api/v1/vulnerabilities/<vuln_id>/remediation-steps/<step_id>	Get single step (aggregation $unwind)	Yes	Any
18	POST	/api/v1/vulnerabilities/<vuln_id>/remediation-steps	Add a remediation step ($push)	Yes	admin, analyst
19	PUT	/api/v1/vulnerabilities/<vuln_id>/remediation-steps/<step_id>	Update a step (positional $)	Yes	admin, analyst
20	DELETE	/api/v1/vulnerabilities/<vuln_id>/remediation-steps/<step_id>	Remove a step ($pull)	Yes	admin, analyst

POST /remediation-steps — Request Body

```
{
  "step_number": 1,
  "step_description": "Apply vendor security patch version 3.2.1",
  "recommended_by": "j.smith",
  "status": "Pending",
  "due_date": "2026-04-01T00:00:00Z",
  "notes": "Requires server restart during maintenance window"
}
```

MongoDB operations used: `$push` (add), positional `$` operator (update), `$pull` (delete), `$unwind` + `$replaceRoot` aggregation (get by ID).

---

5. Activity Log Endpoints (Sub-document CRUD)

Blueprint prefix: `/api/v1/vulnerabilities`

#	Method	Endpoint	Description	Auth	Roles
21	GET	/api/v1/vulnerabilities/<vuln_id>/activity-log	List all activity log entries	Yes	Any
22	GET	/api/v1/vulnerabilities/<vuln_id>/activity-log/<log_id>	Get single log entry (aggregation)	Yes	Any

#	Method	Endpoint	Description	Auth	Roles
23	POST	/api/v1/vulnerabilities/<vuln_id>/activity-log	Add activity log entry ($push)	Yes	admin, analyst
24	DELETE	/api/v1/vulnerabilities/<vuln_id>/activity-log/<log_id>	Delete log entry ($pull) — Admin only	Yes	admin

POST /activity-log — Request Body

```
{
  "action": "Status changed",
  "details": "Vulnerability moved to In Progress after triage review",
  "previous_value": "Open",
  "new_value": "In Progress"
}
```

Note: `performed_by` is automatically set from the JWT token (current user's username).

---

6. Analytics Endpoints (Aggregation Pipelines)

Blueprint prefix: `/api/v1/analytics`

#	Method	Endpoint	Description	Auth	Roles
25	GET	/api/v1/analytics/severity-distribution	Count by severity ($group)	Yes	Any
26	GET	/api/v1/analytics/department-risk	Risk exposure by department ($group, $project)	Yes	Any
27	GET	/api/v1/analytics/overdue-patches	Overdue patch deadlines ($match, $dateDiff)	Yes	Any
28	GET	/api/v1/analytics/patch-compliance	Overall patch compliance rate ($group, $cond)	Yes	Any
29	GET	/api/v1/analytics/vulnerability-trends	Monthly trends ($group by year/month)	Yes	Any
30	GET	/api/v1/analytics/top-affected-assets	Top N assets by vulnerability count	Yes	Any
31	GET	/api/v1/analytics/mean-time-to-remediation	Avg resolution days by severity ($dateDiff)	Yes	Any
32	GET	/api/v1/analytics/risk-scores	Calculated risk scores per vulnerability	Yes	admin, analyst

#	Method	Endpoint	Description	Auth	Roles
33	GET	/api/v1/analytics/summary	Dashboard KPIs ($facet)	Yes	Any
34	POST	/api/v1/analytics/generate-report	Generate report ($out to reports collection)	Yes	admin, analyst
35	GET	/api/v1/analytics/reports	Retrieve latest generated report	Yes	Any

Key MongoDB Aggregation Features Used

Endpoint	Aggregation Stages
severity-distribution	$group, $project, $sort
department-risk	$group, $project (with $cond, $multiply, $add), $sort
overdue-patches	$match, $project (with $dateDiff), $sort
patch-compliance	$group (with $cond), $project (with $divide, $multiply)
vulnerability-trends	$match, $group ($year, $month), $sort, $project
top-affected-assets	$group, $project, $sort, $limit
mean-time-to-remediation	$match, $project ($dateDiff), $group, $sort
risk-scores	$match, $project, $sort
summary (dashboard)	$facet (multiple sub-pipelines), $group (with $cond, $and, $lt)
generate-report	$group, $project, $sort, **$out** (persists to reports collection)

Query Parameters

GET /overdue-patches: ?severity=Critical&department=Engineering

GET /vulnerability-trends: ?months=12 (default: 12)

GET /top-affected-assets: ?limit=10 (default: 10, max: 100)

GET /risk-scores: ?min_score=5.0&department=IT

---

7. Admin Endpoints (User Management)

Blueprint prefix: /api/v1/admin

#	Method	Endpoint	Description	Auth	Roles
36	GET	/api/v1/admin/users	List all users (paginated)	Yes	admin
37	GET	/api/v1/admin/users/<user_id>	Get user details	Yes	admin
38	PUT	/api/v1/admin/users/<user_id>/role	Update user role	Yes	admin

#	Method	Endpoint	Description	Auth	Roles
39	PUT	/api/v1/admin/users/<user_id>/status	Activate/deactivate user	Yes	admin
40	DELETE	/api/v1/admin/users/<user_id>	Delete a user permanently	Yes	admin

Request Bodies

PUT /admin/users/{id}/role

```
{ "role": "admin" }
```

Valid roles: `admin`, `analyst`, `guest`

PUT /admin/users/{id}/status

```
{ "is_active": false }
```

Safety guards: Admins cannot change their own role, deactivate their own account, or delete their own account.

---

8. Error Responses

All errors follow a consistent JSON format:

```
{
  "status": "error",
  "message": "Human-readable error description",
  "code": 400
}
```

HTTP Code	Meaning	Example Trigger
400	Bad Request	Missing/invalid JSON body
401	Unauthorized	Missing/expired/blacklisted token
403	Forbidden	Insufficient role permissions
404	Not Found	Resource does not exist
405	Method Not Allowed	Wrong HTTP method
413	Payload Too Large	Request body > 16 MB
422	Unprocessable Entity	Validation errors (field-level)
429	Too Many Requests	Rate limit exceeded

HTTP Code	Meaning	Example Trigger
500	Internal Server Error	Unhandled server exception

9. Validation Summary

Category	Rules
Strings	Min/max length enforcement, strip whitespace
Enums	Strict value checking against defined constants
Numbers	Type check (int/float), min/max range
Dates	ISO 8601 format with `fromisoformat()` parsing
CVE ID	Regex: `CVE-\d{4}-\d{4,}`
Email	Standard email regex pattern
Password	Min 8 chars, uppercase, lowercase, digit, special char
ObjectId	BSON ObjectId format validation

10. Database Collections & Indexes

Collection	Purpose
`vulnerabilities`	Main vulnerability documents with sub-document arrays
`users`	User accounts with hashed passwords
`blacklist`	Revoked JWT tokens
`reports`	Generated analytics reports (`$out` target)

Indexes:

- Single field: `severity`, `status`, `cvss_score`, `department`, `patch_due_date`, `patch_applied`, `created_at`, `vulnerability_type`, `discovery_method`
- Compound index: `(severity, status, department)` — optimises common filter combinations
- Text index: `vulnerability_title`, `description` (for `$text` search)
- 2dsphere: `location` (for `$geoNear` queries)
- User unique indexes: `email`, `username` (enforce uniqueness)
- TTL: `blacklist.blacklisted_at` (auto-expire after 24 hours)

Complete Endpoint Count Summary

Category	Count
Health Check	1
Authentication	7
Vulnerabilities	7

Category	Count
Remediation Steps	5
Activity Log	4
Analytics	11
Admin	5
Total	**40**

End of API Endpoint Summary